Assignment 6

Introduction to Network Security and Cryptography in Network Security

Subject: Cryptography and Network Security (BCA309T)

Answers to Q1 - Q5

Q.	Topic
Q1	Network security: principles, objectives and the CIA + AAA properties
Q2	Threat landscape, network attacks, vulnerabilities and preventive measures
Q3	Legal and ethical considerations in network security
Q4	Role of cryptography; SSL/TLS and IPsec
Q5	Public Key Infrastructure (PKI), digital certificates and Certificate Authorities

Q1. Network Security: Principles and Objectives

Define network security and explain its fundamental principles and objectives. Discuss the importance of confidentiality, integrity, availability, authentication, and authorization.

1.1 Definition

Network security is the set of policies, practices, technologies and devices used to protect the usability, reliability, integrity and safety of a computer network and the data travelling across it. It prevents unauthorized access, misuse, modification, or denial of network resources. It combines hardware (firewalls, routers, IDS/IPS), software (antivirus, VPN clients, encryption tools) and administrative controls (policies, training, audits).

Example: A college network uses a firewall to block outside traffic, a VPN for remote staff, strong passwords for logins, and encrypted Wi-Fi (WPA3) so that student records cannot be read or altered by outsiders.

1.2 Fundamental Principles

- **Defence in depth:** multiple layers of protection (perimeter firewall, host firewall, antivirus, access control) so that failure of one layer does not expose everything.
- **Least privilege:** users and programs get only the minimum access needed for their job.
- **Separation of duties:** critical tasks are split among several people to reduce fraud and error.
- **Fail-safe defaults:** access is denied unless explicitly granted.
- **Economy of mechanism and complete mediation:** keep designs simple and check every access request.
- **Security by design, not obscurity:** security must not rely on keeping the design secret.

1.3 Objectives

- Protect data from unauthorized disclosure, change or loss.
- Keep services and resources available to legitimate users.
- Detect, prevent and respond to attacks quickly.
- Verify identities and control what each user can do.
- Provide accountability and traceability (logging and non-repudiation).
- Meet business, legal and regulatory requirements.

1.4 The CIA Triad and Supporting Properties

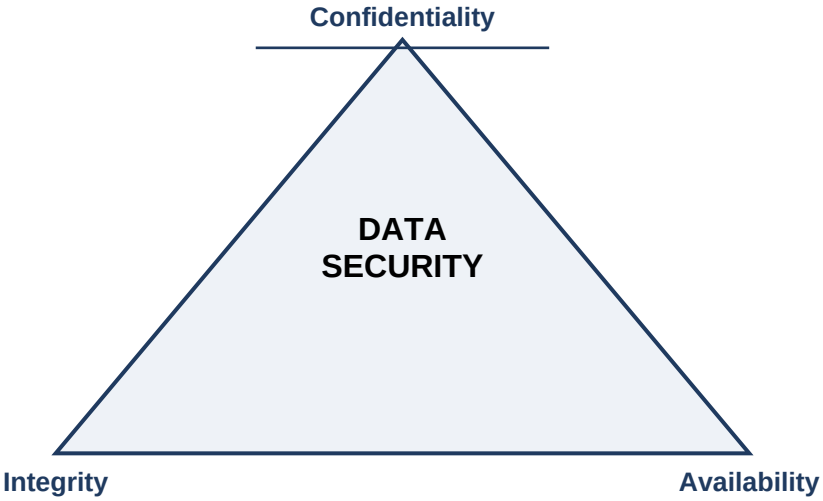

Fig. 1: The CIA triad - the three core goals of security.

Property	Meaning	Importance / Example	Common controls
Confidentiality	Information is accessible only to authorized parties.	Prevents leakage of passwords, bank details, medical records. Sniffing of unencrypted HTTP traffic breaks it.	Encryption (AES, TLS), access control, VPN
Integrity	Data is accurate and has not been altered in storage or transit.	A changed bank transfer amount or tampered software update destroys trust.	Hashing (SHA-256), digital signatures, MACs, checksums
Availability	Systems and data are accessible when needed.	A DDoS attack that takes down an online exam portal violates availability.	Redundancy, backups, load balancers, DDoS protection, UPS
Authentication	Verifying that a user or device is who it claims to be.	Stops impersonation; e.g. login with password + OTP.	Passwords, biometrics, OTP/MFA, certificates, Kerberos
Authorization	Deciding what an authenticated entity may access or do.	A student can view marks but cannot edit them; an admin can.	ACLs, RBAC, file permissions, firewall rules

Additional properties: *Non-repudiation* (a sender cannot deny sending a message, achieved with digital signatures) and *Accountability/Auditing* (all actions are logged to a user).

Authentication vs Authorization: authentication answers *'Who are you?'* while authorization answers *'What are you allowed to do?'*. Authorization always follows successful authentication. Together with Accounting (logging) they form the AAA framework.

Conclusion: Confidentiality, integrity and availability define *what* must be protected, while authentication and authorization define *who* may reach it. A secure network must balance all five.

Q2. Threat Landscape, Attacks and Vulnerabilities

Explain the threat landscape in network security. Discuss different types of network attacks and vulnerabilities, along with examples and preventive measures.

2.1 Threat Landscape

The threat landscape is the overall picture of threats, threat actors, attack methods and vulnerabilities that can affect a network at a given time. It keeps changing as technology (cloud, IoT, remote work, AI) grows.

Threat actors

- **Script kiddies:** low-skill users running ready-made tools.
- **Hacktivists:** attack for political or social causes.
- **Cybercriminals / organised crime:** financial gain (ransomware, fraud).
- **Insiders:** employees or contractors misusing access, intentionally or by mistake.
- **Nation-state / APT groups:** espionage and sabotage with high resources.

2.2 Types of Network Attacks

Attacks are broadly classified as **passive** (only observe/collect data; hard to detect, e.g. eavesdropping, traffic analysis) and **active** (modify, inject or disrupt; e.g. DoS, spoofing, MITM).

Attack	Description	Example	Prevention
Eavesdropping / Sniffing	Capturing packets travelling on the network.	Wireshark on open Wi-Fi reading HTTP passwords.	Encryption (TLS, VPN), switched networks, WPA3
Man-in-the-Middle (MITM)	Attacker secretly sits between two parties, reading or altering data.	Fake Wi-Fi hotspot, ARP poisoning, SSL stripping.	TLS with certificate validation, HSTS, dynamic ARP inspection
IP / ARP / DNS Spoofing	Forging addresses or replies to impersonate a trusted host.	DNS cache poisoning redirecting a bank URL to a fake site.	DNSSEC, ingress filtering, static ARP, authentication
DoS / DDoS	Flooding a target to exhaust bandwidth or resources.	SYN flood, UDP flood, botnet-based HTTP flood (Mirai).	Rate limiting, SYN cookies, CDN/scrubbing, redundancy
Phishing / Social engineering	Tricking people into revealing credentials or running malware.	Fake 'bank' email with a login link.	User awareness, email filters, MFA
Malware	Malicious software: virus, worm, trojan, ransomware, spyware.	WannaCry worm encrypting files and spreading via SMB.	Antivirus/EDR, patching, backups, least privilege
Password attacks	Brute force, dictionary, credential stuffing.	Automated guessing of SSH logins.	Strong passwords, lockout, MFA, rate limiting
Replay attack	Re-sending a captured valid message to gain access.	Re-using a captured authentication token.	Timestamps, nonces, sequence numbers, session tokens

Attack	Description	Example	Prevention
SQL injection / XSS	Injecting malicious code via input fields of web apps.	*' OR '1'='1* in a login form.	Input validation, prepared statements, WAF
Port scanning / Reconnaissance	Probing hosts for open ports and services before attack.	Nmap scan of a server range.	Firewalls, IDS/IPS, closing unused ports
Rogue AP / Evil twin	Unauthorized Wi-Fi access point mimicking a real one.	Fake 'Campus_WiFi' hotspot.	WPA3-Enterprise, wireless IPS, user education

2.3 Common Vulnerabilities

- **Software flaws:** buffer overflows, unpatched systems, zero-day bugs.
- **Misconfiguration:** default passwords, open ports, unnecessary services, overly permissive firewall rules.
- **Weak authentication:** simple passwords, no MFA, shared accounts.
- **Protocol weaknesses:** clear-text protocols (Telnet, FTP, HTTP), no authentication in ARP/DNS.
- **Human factor:** lack of awareness, insider negligence.
- **Physical weaknesses:** unprotected server rooms and network ports.
- **Third-party / supply chain and IoT devices** with poor security.

2.4 Preventive Measures

- Use **firewalls** and network segmentation (DMZ, VLANs).
- Deploy **IDS/IPS** and continuous monitoring (SIEM).
- Apply **regular patches** and updates; run vulnerability scans and penetration tests.
- Encrypt data in transit and at rest; use VPNs for remote access.
- Enforce **strong authentication** (MFA) and least privilege.
- Keep **backups** and an incident response plan.
- Train users against phishing and social engineering.
- Harden devices: disable unused services, change defaults.

Conclusion: Because attackers continually evolve, network security must be proactive: identify assets, assess risk, layer defences, monitor continuously and respond quickly.

Q3. Legal and Ethical Considerations in Network Security

Discuss the legal and ethical considerations in network security. Explain the importance of data privacy, responsible security testing, authorized access, and compliance with cybersecurity laws.

Security professionals hold powerful skills and access. Legal rules define what is *permitted*; ethics defines what is *right*. Both are essential so that security work protects people instead of harming them.

3.1 Data Privacy

- Organizations collect personal data (names, IDs, health, financial details); it must be collected for a clear purpose, kept minimal, stored securely and not shared without consent.
- Key principles: **consent, purpose limitation, data minimisation, accuracy, storage limitation, security safeguards and accountability**.
- Breaches cause identity theft, financial loss, reputational damage and heavy fines.
- Technical measures: encryption, anonymisation/pseudonymisation, access control, secure deletion, breach notification procedures.
- Relevant regulations: India's **Digital Personal Data Protection Act, 2023**, EU **GDPR**, US **HIPAA** (health data), **PCI-DSS** (card data).

3.2 Responsible Security Testing

Security testing (vulnerability assessment, penetration testing, red teaming) is legal and ethical only when done responsibly:

- Obtain **written permission** defining scope, targets, timings and methods (rules of engagement).
- Stay strictly within scope; avoid damaging systems or disrupting services.
- Protect any data seen during testing; do not copy or misuse it; sign an NDA.
- Report findings honestly and promptly to the owner; follow **responsible (coordinated) disclosure** - give vendors reasonable time to fix before public release.
- Distinguish **white-hat** (authorized, ethical), **black-hat** (malicious, illegal) and **grey-hat** (unauthorized but not malicious - still potentially illegal) hackers.

3.3 Authorized Access

- Accessing a computer or network without permission, or exceeding granted permission, is a crime even if no damage is done.
- Organizations must implement **access control**: unique IDs, role-based access, periodic access reviews, prompt revocation when staff leave.
- Users must follow acceptable use policies and never share credentials.
- Monitoring of employees must be lawful, disclosed in policy and proportionate.

3.4 Compliance with Cybersecurity Laws

Law / Standard	Scope (brief)
Information Technology Act, 2000 (India)	Sec 43 (damage to computer systems, unauthorized access), Sec 66 (computer-related offences/hacking), Sec 66C/66D (identity theft, cheating by impersonation), Sec 66F (cyber terrorism), Sec 72 (breach of confidentiality). Amended in 2008.
Digital Personal Data Protection Act, 2023 (India)	Governs processing of digital personal data, consent, rights of data principals and duties of data fiduciaries; penalties for breaches.
CERT-In Directions (2022)	Mandatory reporting of specified cyber incidents to CERT-In within 6 hours; log retention requirements.
GDPR (EU)	Strict data protection, rights of individuals, 72-hour breach notification, fines up to 4% of global turnover.
Computer Fraud and Abuse Act (USA)	Criminalizes unauthorized access to protected computers.
ISO/IEC 27001, NIST CSF, PCI-DSS, HIPAA	Standards/frameworks for information security management and sector-specific compliance.

3.5 Ethical Considerations

- **Integrity and honesty** in reporting and professional conduct.
- **Confidentiality** of client and user information.
- **Do no harm** and respect for others' privacy and property.
- **Professional competence** and continuous learning.
- Follow professional codes of ethics such as $(ISC)^2$, ACM and EC-Council codes.
- Avoid conflicts of interest; refuse to take part in illegal or unethical activity.

Example: A tester finds a flaw in a university portal. The ethical path is to inform the administrators privately and allow it to be fixed. Downloading student records or publishing the flaw first would be illegal and unethical.

Conclusion: Following legal requirements and ethical principles builds trust, avoids penalties and ensures security measures serve and protect users.

Q4. Cryptography in Network Security: SSL/TLS and IPsec

Explain the role of cryptography in securing network communications. Describe the working and security features of SSL/TLS and IPsec protocols.

4.1 Role of Cryptography

Cryptography is the science of transforming data into an unreadable form (encryption) and recovering it (decryption) using algorithms and keys. In networks it delivers the main security services:

Service	Cryptographic tool
Confidentiality	Symmetric encryption (AES, ChaCha20); key exchange with RSA / Diffie-Hellman / ECDH
Integrity	Hash functions (SHA-256/384) and Message Authentication Codes (HMAC, AEAD tags such as GCM)
Authentication	Digital certificates, digital signatures (RSA, ECDSA), pre-shared keys
Non-repudiation	Digital signatures made with the sender's private key
Replay protection	Nonces, timestamps, sequence numbers

Types: *Symmetric* cryptography uses one shared secret key (fast, used for bulk data); *asymmetric* uses a public/private key pair (slower, used for key exchange and signatures); *hash functions* create fixed-size digests for integrity. Real protocols use a **hybrid** approach: asymmetric methods to authenticate and agree on a key, then symmetric encryption for the data.

4.2 SSL/TLS (Secure Sockets Layer / Transport Layer Security)

TLS is the standard protocol that secures communication between a client and server over TCP, operating between the transport and application layers. It protects HTTPS, SMTPS, IMAPS, FTPS, etc. SSL (v2/v3) is obsolete and insecure; TLS 1.2 and **TLS 1.3** are current.

Components

- **Handshake protocol:** negotiates version and cipher suite, authenticates the server (and optionally the client) and establishes shared keys.
- **Record protocol:** fragments data, compresses/optionally, adds MAC/AEAD tag, encrypts and transmits it.
- **Alert protocol:** signals errors and closure.
- **Change Cipher Spec** (TLS 1.2): tells the peer to start using the negotiated keys.

Working (simplified handshake)

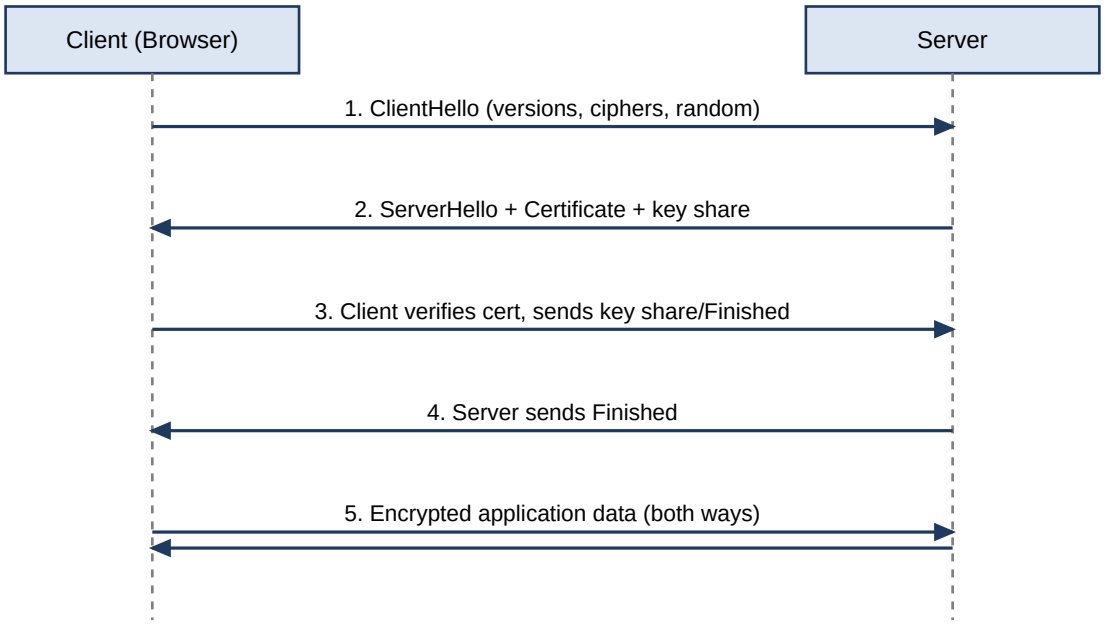

Fig. 2: Simplified TLS handshake and secure data transfer.

- **ClientHello:** client sends supported TLS versions, cipher suites and a random number.
- **ServerHello and certificate:** server picks the cipher suite, sends its random value and its X.509 certificate.
- **Verification:** client checks the certificate chain, validity period, domain name and revocation status against trusted CAs.
- **Key exchange:** client and server derive a shared *session key* (ephemeral Diffie-Hellman in TLS 1.3, or encrypted pre-master secret with RSA in older versions).
- **Finished messages:** both sides verify the handshake was not tampered with.
- **Secure data transfer:** application data is encrypted with the symmetric session key and integrity-protected.

Security features of TLS

- **Confidentiality** via symmetric encryption (AES-GCM, ChaCha20-Poly1305).
- **Integrity** via HMAC / AEAD so any modification is detected.
- **Server (and optional client) authentication** via X.509 certificates, preventing MITM and fake sites.
- **Forward secrecy** through ephemeral key exchange (ECDHE): old sessions stay safe even if the server's private key leaks later.
- **Replay protection** through sequence numbers and nonces; session resumption for efficiency.
- TLS 1.3 removes weak algorithms, reduces the handshake to one round-trip and encrypts most handshake messages.

4.3 IPsec (Internet Protocol Security)

IPsec is a suite of protocols that secures communication at the **network layer (IP)**, protecting all traffic between hosts, gateways or networks regardless of the application. It is the foundation of many site-to-site and remote-access **VPNs**.

Main components

Component	Function
AH (Authentication Header)	Provides integrity, data-origin authentication and anti-replay for the IP packet; **no encryption**.
ESP (Encapsulating Security Payload)	Provides **confidentiality** (encryption) plus integrity, authentication and anti-replay. Most widely used.
IKE (Internet Key Exchange, IKEv2)	Authenticates peers and negotiates keys and algorithms; creates Security Associations.
Security Association (SA)	One-way logical agreement defining algorithms, keys, lifetime and SPI; stored in the SAD.
SPD / SAD	Security Policy Database decides which traffic is protected; Security Association Database holds active SAs.

Modes of operation

Mode	Description	Typical use
Transport mode	Only the payload of the IP packet is protected; original IP header kept.	Host-to-host communication
Tunnel mode	Entire original IP packet is encapsulated and protected, with a new outer IP header.	Gateway-to-gateway (site-to-site) and remote-access VPN

Working

- **Phase 1 (IKE SA):** peers authenticate each other (pre-shared key or certificates) and create a secure channel using Diffie-Hellman.
- **Phase 2 (IPsec/Child SA):** peers negotiate the ESP/AH parameters and keys for the actual data traffic.
- **Data transfer:** packets matching the policy are encrypted/authenticated and sent; the receiver verifies, decrypts and forwards them.
- **Rekeying/termination:** SAs expire after a lifetime and are renewed.

Security features of IPsec

- Confidentiality, integrity, authentication and anti-replay protection at IP level.
- Transparent to applications - no application changes needed.
- Strong algorithms (AES, SHA-2, DH/ECDH) and perfect forward secrecy options.
- Protects against sniffing, spoofing, MITM and session hijacking.

4.4 Comparison: TLS vs IPsec

Feature	SSL/TLS	IPsec
Layer	Between transport and application (L4-L7)	Network layer (L3)
Protection scope	Per application/connection (e.g. a browser session)	All IP traffic between hosts/networks
Typical use	HTTPS, email, secure web services, SSL VPN	Site-to-site VPN, remote-access VPN
Authentication	Usually server certificate; client optional	Pre-shared keys or certificates for both peers
Setup	Easy, no client software for web	More complex; needs configuration/client

Conclusion: Cryptography underpins every secure network service. TLS protects individual application sessions, while IPsec protects traffic at the IP level; both use hybrid cryptography, authentication and integrity checks.

Q5. Public Key Infrastructure (PKI)

What is PKI? Explain its components and working. Discuss the role of digital certificates and Certificate Authorities in establishing trust and securing network communications.

5.1 What is PKI?

Public Key Infrastructure (PKI) is a framework of hardware, software, policies, roles and procedures used to create, manage, distribute, use, store and revoke digital certificates and manage public-key encryption. It solves a key problem of asymmetric cryptography: *how do we know that a public key really belongs to the person or server who claims it?* PKI binds public keys to identities through trusted third parties.

5.2 Components of PKI

Component	Role
Certificate Authority (CA)	Trusted entity that verifies identities and issues, signs and revokes digital certificates. Can be hierarchical: Root CA and Intermediate CAs.
Registration Authority (RA)	Verifies the identity of applicants on behalf of the CA and forwards approved requests.
Digital certificate (X.509)	Electronic document binding a public key to an identity, signed by the CA.
Public/private key pair	Public key is shared in the certificate; private key is kept secret by the owner.
Certificate repository / directory	Central store (LDAP, web) where certificates and revocation lists are published.
CRL and OCSP	Certificate Revocation List and Online Certificate Status Protocol - tell users whether a certificate has been revoked.
Certificate Management System	Handles issuing, renewal, revocation, key backup/recovery and policies (CP/CPS).
End entities	Users, servers, devices or applications that hold and use certificates.

5.3 Working of PKI

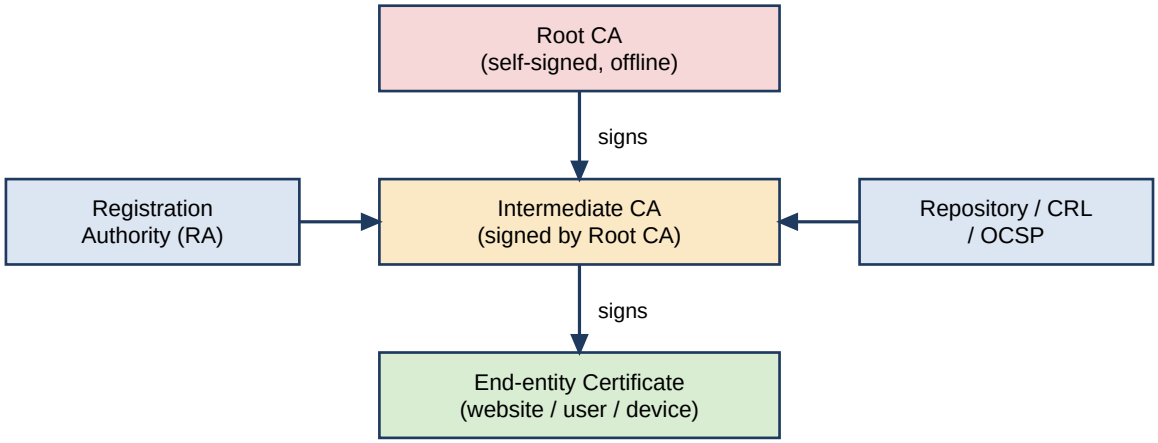

Fig. 3: PKI hierarchy and chain of trust.

- **Key generation:** the applicant (e.g. a web server) generates a public/private key pair.
- **Certificate Signing Request (CSR):** the applicant sends the public key and identity details (domain, organisation) to the RA/CA.
- **Verification:** the RA/CA validates the identity (domain, organisation or extended validation).
- **Issuance:** the CA signs the certificate with its own private key and returns it.
- **Use:** during communication (e.g. TLS) the server presents the certificate; the client verifies the CA's signature using the CA's public key stored in its trusted root store, checks validity dates, domain name and revocation status.
- **Secure communication:** once verified, the client trusts the public key and uses it to authenticate the server and establish encryption keys.
- **Renewal / revocation:** certificates expire (typically 90 days to 1 year) or are revoked if the private key is compromised; revocation is published through CRL/OCSP.

5.4 Digital Certificates

A digital certificate (standard **X.509**) is like an electronic ID card. Typical fields:

- Version and serial number
- Subject (owner's name / domain) and subject public key
- Issuer (the CA) and validity period (not before / not after)
- Signature algorithm and the CA's digital signature
- Extensions: key usage, subject alternative names (SAN), CRL/OCSP locations

Types: Domain Validated (DV), Organisation Validated (OV), Extended Validation (EV), wildcard, code-signing, email (S/MIME) and client certificates.

Role: certificates provide *authentication* (proves identity), enable *secure key exchange* for encryption, support *digital signatures* (integrity and non-repudiation), and are used in HTTPS, VPNs, secure email, code signing and smart cards.

5.5 Role of Certificate Authorities in Trust

- **Third-party trust:** users may not know a website, but they trust the CA that vouches for it. Operating systems and browsers ship with a built-in list of trusted root CAs.
- **Chain of trust:** End-entity certificate is signed by an Intermediate CA, which is signed by a Root CA; validation follows the chain up to a trusted root. Root keys are kept offline for safety.
- **Identity assurance:** CAs follow strict validation and audit rules (e.g. WebTrust, CA/Browser Forum baseline requirements).
- **Revocation management:** CAs publish CRLs/OCSP responses so compromised certificates are rejected.
- **Prevents MITM:** an attacker cannot present a valid certificate for a domain they do not control; a forged certificate fails validation and browsers show a warning.
- **Examples:** Let's Encrypt, DigiCert, Sectigo, GlobalSign; in India, licensed CAs such as eMudhra and (n)Code for digital signature certificates under the IT Act.

5.6 Risks and Limitations

- Compromise of a CA can undermine trust (e.g. DigiNotar breach in 2011).
- Private key theft or poor key management.
- Delays or failures in revocation checking; expired certificates causing outages.
- Cost and complexity of managing certificates at scale.

Conclusion: PKI provides the trust foundation of the Internet. Certificates and CAs allow strangers to authenticate each other and set up encrypted, tamper-proof communication through TLS, IPsec, secure email and digital signatures.